

Implementing Zero Trust

Colin Barber, CB

Department of Computer Science and Information Systems, Texas A&M-Commerce, Set 21, 2022

cbarber5@leomail.tamuc.edu

Abstract: This is a research paper on how to implement a zero-trust trust solution in a network. This paper will explore what zero trust architecture is as it pertains to the context of the application for a system of networks. This document will explore a zero-trust solution to access control with the necessary tools needed for the infrastructure to achieve zero trust for the goal of a smart office with a Cloud server and user authentication. Along with why zero trust networks provide proper security that can scale and implement new elements such as additional devices or software. This document gives an abstract overview of Zero Trust architecture as a use case for a smart office.

Keywords: Software Defined Perimeter (SDP), Zero Trust Network (ZTN), architecture, Network Security, Cloud server

1 INTRODUCTION

Zero trust is trust that is given implicitly following the standards of verify explicitly, always assume a breach, and using least privilege access. This paper will not cover the perimeter boundaries at zero trust architecture but will cover how to implement zero-trust to verify explicitly for and user on a cloud server. This will be done by having the use case of a smart office (smart home) that would like to use the zero-trust model, as follows this paper will cover the basic needs of information needed to achieve zero-trust on a cloud server with user authentication. Usually, a user would enter credentials on a console to gain access to a cloud server. In the case of zero-trust, how would that user even gain access to the console? Does that user even have the proper rights or credentials to see that there is a cloud server or even access to it? Zero-trust must verify first which means that the user would have to authenticate, then be given less privileged access to the cloud server and its resources. Then zero-trust policy would have to validate who the user is that is accessing the cloud server after these steps in the zero-trust model the user will have access to the cloud server. The proceeding structure of this document is as follows background, design, implementation analysis, related works, and conclusion.

2 BACKGROUND

Trust is a concept in computer science that assumes a user, program, and or device will not violate set conditions for functionality. This would mean that if an application has access and rights to read a file then that application should not be able to write or modify files. If that is not the case, then that application has gone beyond the set conditions and has broken trust. The solution that will be presented elevates trust and does not even allow resources to access other resources beyond their set scope. This can be achieved in the zero-trust model in which trust is given implicitly by following verify explicitly, assuming a breach, and using least privilege access. It should be noted that zero-trust has trust, but the default case is no trust if the steps to gain trust in the model are not met. This would be the zero-trust policy on the network that will give trust in the instance of identity verification.

Taking the concept of trust in zero-trust that uses least privilege most commonly, the creation and use of sessions. In these sessions, only the resources needed are available per user. During these sessions, they are utilizing segmentation and isolation of the resources in the system of networks in the architecture. If an employee in the HR department enters the zero-trust model as a user then they should have access to email services but, shouldn't have access to configure firewalls. Usually, done by the zero-trust policy and software-defined controls leading to basic control flow of authentication of users or devices for access to resources or assets. Who is the entity? What did they access? For how long? Are all tracked in logs this is a security measure. Other security measures are IDS which detects if something irregular is happening, then the system will assume a breach has occurred resulting in isolation in a sandbox environment or denial of access. Additionally, challenges to accessible resources occur while a session is in the process meaning that the verifying implicitly is active; a session will be

checked for authorization not only at the start of the session but during and with any switching to other resources in the system.

In addition, following the best practices for zero-trust, the ZT policy should be at the center of the network surrounded by the assets and resources in the network. This could involve PLCs, HVC systems, routers, servers, and workstations to name a few, with some type of security measures like IDS or firewalls. This would most likely be the scheme of any architecture that uses zero-trust as the model. Programs and software that are used for zero-trust solutions use some type of log system to keep track of sessions. These could be something like OKTA, AZURE, or Microsoft products.

2.1 Algorithms

The Trust Algorithm (TA) is the process algorithm that the Zero Trust architecture follows to classify assets or user authentication. This algorithm is the core structure where trust is granted based on verification implicitly. The TA is something like a policy engine that either grant access or denies assets that follow the verify explicitly concept.

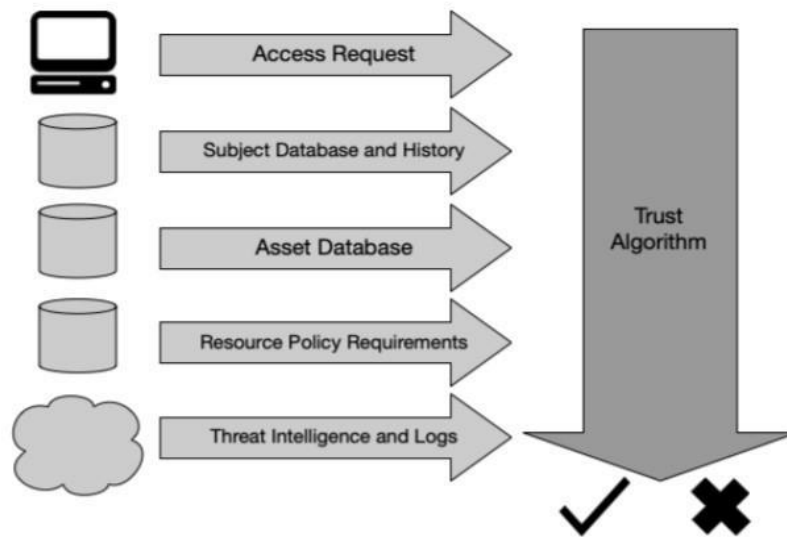


Figure 1 Trust Algorithm as the flow of access is visually represented [2]

The figure above is the basic form of trust that follows when a user requests access to resources in zero trust architecture. A request is followed by some type of verification and checks to see if trust is being broken. If policies or a threat is detected the system will assume a breach in the system and will act accordingly to policies in place. In line with the security measures in place, this could be the isolation of the session in a sandbox environment or simply denying access. For further information please refer to [Zero Trust Architecture for IoT Devices].

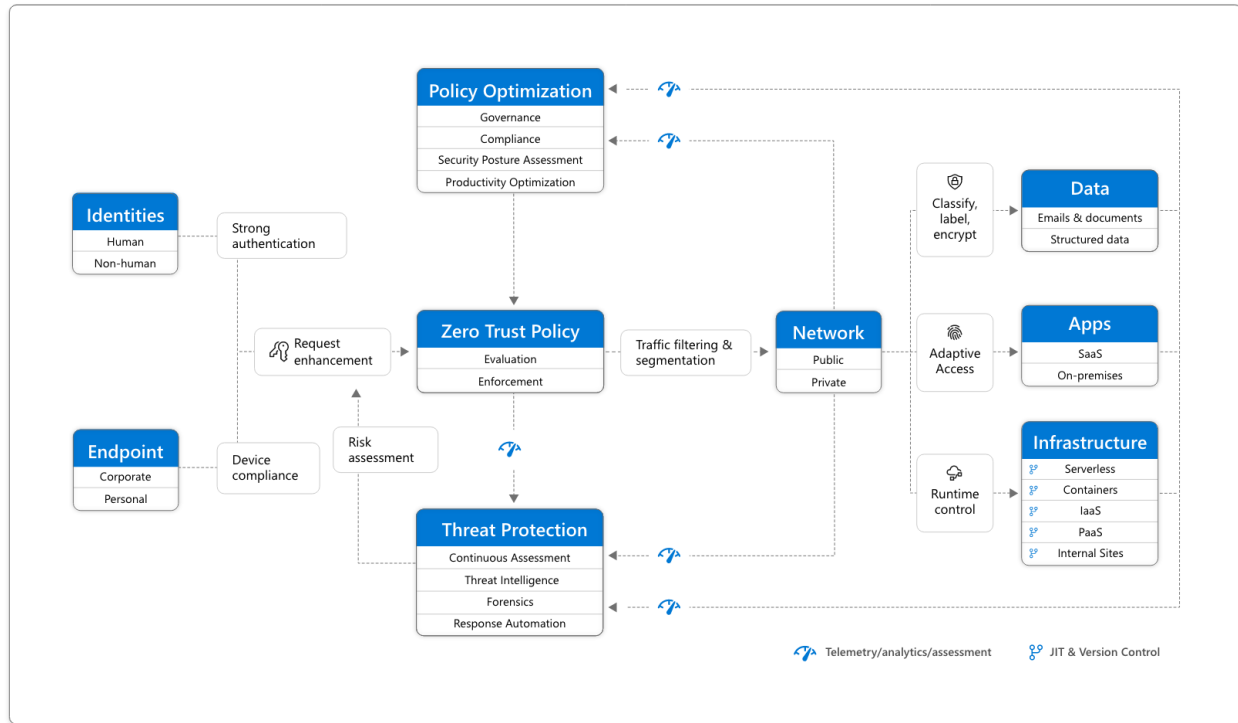


Figure 3: OSI chart of the Flow of zero trust [1]

In Figure 3 you can observe the flow of trust in a network on how trust can be achieved in a zero-trust structure. This is the zero-trust model that should be the goal for the implementation of the zero-trust scheme of security. It should be noted that a zero-trust solution is an identity solution security scheme that is aimed to solve the issue with software-defined perimeters of threat vectors gaining access to nodes on the network and gaining admin.

2.2 Smart Office

A smart office is an office that contains a collection of devices. These additions usually enhance a user's experience by offering convinces or integrated systems and or controls that add to the function of the office or work efficiency. In such, cases a smart office can have amenities such as a temperature control system, air purifier, or door sensors. In other cases, they can have workstations, network gateways, PLCs, Servers, and GPU Racks that aid in the control of a network or the office itself.

The use case for this document is a smart office below is figure 2 is the architecture. The smart office has a temperature control system, air purifier, door sensors, PLC, Servers, Laptop, workstation, GPU rack, and storage devices. For the use case of the paper, it is a smart office that wants to integrate zero-trust for the users with the @spairl.org domain name. To their Oracle cloud server that is implemented as a web-based application.

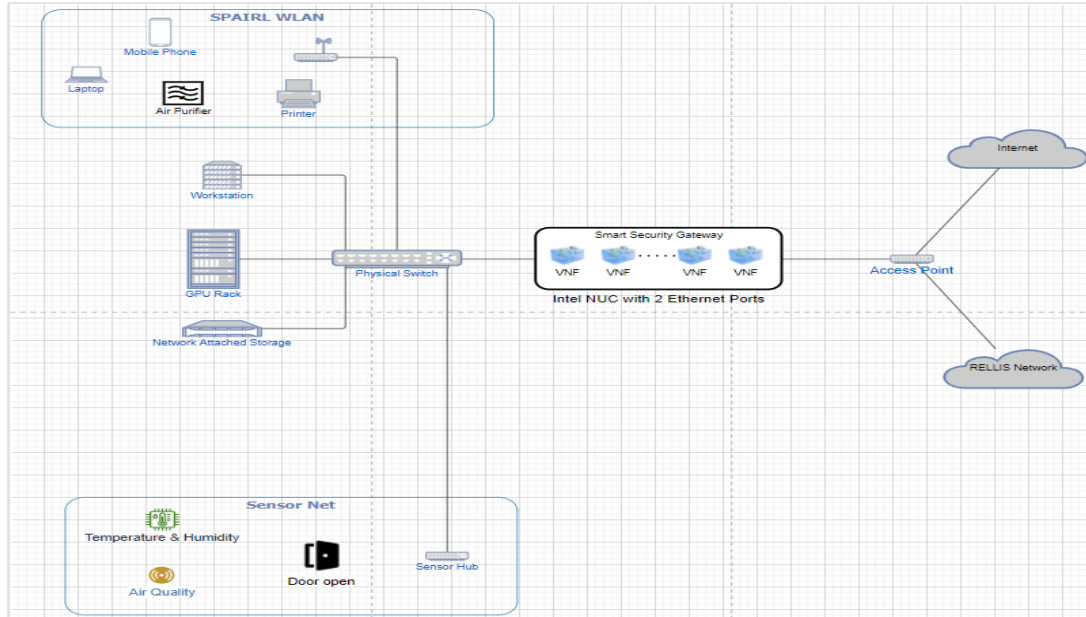


Figure 2: Use Case Architecture

3 DESIGN

Following the concept of a zero-trust solution of verifying explicitly, giving least privilege access, and always assume breach you would have to create your own solution for zero-trust bases on the current assessment of the network and architecture. This can be done by mapping your environment, Adapting the architecture to data flows, and using asset and device identities [7].

To achieve this the programs and software to be used are OKTA, Cloudflare, and Tailscale. The cloud server will be an Oracle cloud product. OKTA will function as the center of the architecture is the ZT policy as well as, IAM the identity of users and devices. Cloudflare will act as a firewall will all assets behind this firewall. Tailscale's function is a secure access route to resources such as the Oracle cloud server web-based application.

Cloudflare will handle access control for the network. OKTA is the IAM ensuing identity management. Tailscale is a peer-to-peer mesh gateway or tunnel to functions as SSH access to the web-based application which is the cloud server. For clarification, the trust algorithm will be presented.

- The user asks Cloudflare (access control) for user authentication
- Cloudflare will direct the user to OKTA (IAM)
- If authorization occurs in IAM
- Resources will be granted to the user in a session by ZT policies enforced by Cloudflare and OKTA
- Tailscale will ensure that the communications and connects are secure while in the network from outside devices
- SSH authentication will occur for Tailscale to grant SSH access control to the web application (Cloud Server)

Will these steps zero-trust can be achieved will this model of mapping, data flow, and device and assets identities with the aid of using OKTA, Cloudflare, and Tailscale. This design is to ensure that the zero-trust concepts and best practices previously stated are met like sessions, segmentation, isolation, verify explicitly, least privilege, and assume breach. In addition, with OKTA and Cloudflare the control of certain policies the ZT policy can be configured. This would mean blacklisting and whitelisting applications, websites, and or users/devices can be done. If not noticed, then this should be stated this would mean that this ZT solution would be scalable to an enterprise level of security and will need adaptation of other features provided by Cloudflare and OKTA based on the network infrastructure.

3.1 OKTA

OKTA is an independent provider that gives their users integration of zero-trust for enterprise assets ranging from a universal directory, API access management, and access gateways as products that they offer to clients. OKTA should allow for user identity and verification, to a particular object in the network for authenticated users [3]. OKTA also has its imputation of zero-trust policy controls to fit the needs and goals of the network that is trying to achieve zero-trust. OKTA is an identity provider that can act as an IAM for a network of assets.

3.2 Cloudflare

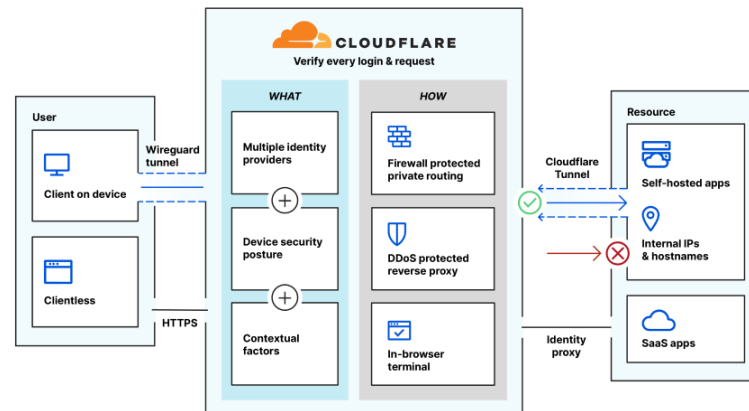


Figure 4 Cloudflare structure for Cloud security [9]

Cloudflare is a firewall that uses the zero-trust model that will allow for verifying explicitly, giving least privilege access, meaning that access is not granted until the user is first authenticated. Then the user may have access to the resources in the network. Cloudflare is an interface software that has logs, gateway, and firewall configurations. This program interface can allow for control of applications and domains that the network may have in their system. Zero-trust policies can also be created and controlled on this software along with gateways, edge network devices, API controls, and email services. The network security configurations can also be created and pushed to deployment from Cloudflare. Cloudflare also, has intrusion detection devices on their server, logs, tracking of network traffic, and follows best practices of creating sessions and isolation. This program is designed to give the user access control of the network that assets have been defined in the network.

3.3 Tailscale

Tailscale is like a firewall or VPN service that makes the devices and applications you own accessible anywhere in the world, securely and effortlessly. It enables encrypted point-to-point connections using the open-source Wire Guard protocol in a peer-to-peer mesh network [9]. This is a peer-to-peer mesh gateway which means that device communicates with each other to transfer data in a one-to-one, one-to-many, or many-to-many. It is better to explain Tailscale as a VPN service but, this isn't what the program is performing. The idea of a VPN tunneling method that is encrypted communicates as a peer-to-peer mesh way that is visualized by the network as a gateway node. This is what Tailscale behaves like if being used in a network.

4 IMPETMETAON

In the use case, the solution being implemented is the use of OKTA, Cloudflare, and Tailscale in the architecture with OKTA being in the center of the network. Assets around OKTA would be the devices, Cloudflare, applications, and Tailscale. This is the model for the zero-trust solution after the assessment of assets and the goal of zero-trust security for a web-based application which is the Oracle cloud server. The smart office has users, applications (email service, web Oracle cloud), and devices. So, to ensure that zero-trust is achieved we must follow the zero-trust concepts. Verify explicitly by OKTA as an IAM so creating an account with them is necessary. You will have to define a namespace (@sparil.org) for OKTA as they will create a URL address for identity controls. Once in OKTA, you are allowed to add and integrate applications that are supported by

OKTA services. Adding Cloudflare our AC will be next into OKTA's interface as a known application this will allow for IAM for Cloudflare. Creating a Cloudflare account with the credentials used by OKTA will be done for the user by OKTA when launched from OKTA to Cloudflare. OKTA will launch Cloudflare via OKTA this will allow for least privileged access and always assume breach. In Cloudflare you can add your domain name of websites this would be the Oracle cloud server that is implemented as a web-based application. Selection of the DNS on Cloudflare will add the A, Cname, AAA, and MX records onto Cloudflare, and the getting started prompt will allow you to add the domain to Cloudflare's interface this will allow for DNS management of the records of the domain. This is done by adding the URL of the website and then replacing the website's domain register sever names with Cloudflare name servers that have been generated. You can then deploy Cloudflare services once Cloudflare has ensured ownership of the website. For the page rules in Cloudflare, the selection URL forwarding rules should be selected to <https://okta.spairl.org> the identity provider URL this is a zero-trust policy that will enforce segmentation and explicitly of verification. To add Tailscale you would need to integrate the application into OKTA (IAM) and then into Cloudflare (Access Control) to do this you will need to client ID and client secret ID that can be found at the OKTA interface after integration. These IDs will have to be added to the Cloudflare UI under the tunneling section.

5 ANALYSIS

The zero-trust solution that has been provided is a solution to identify management and SDP issues. This desired goal of implicit verification of @spairl.org users on the web-based application can be achieved with the zero-trust solution provided in this paper. This is relevant to the observation of the use case of the smart office which is simply a scaled-down enterprise network. Meaning that this solution can be scalable for more websites, applications, and users. Along with the amount of access control generated from the Cloudflare application and OKTA and Cloudflare zero-trust policies working in tangent to configure to the needs of the network. Tailscale will allow for secure communication of devices and applications within the network. IP addresses of devices, website URLs, and simply put the architecture created are encrypted with a peer-to-peer gateway on the network. The major issues at the current stage of development would be the knowledge required about the network and flow of data needed to create a proper zero-trust policy and edge case with these policies.

6 RELATED WORKS

The core takeaway from other solutions using the zero-trust model from other works is the determined zero-trust your own solution since the zero-trust model is a concept to achieve the solution of zero-trust. Meaning that the approach would generally aid more than the details on how. The topic of cloud servers that use a zero-trust solution is given as mapping your environment, Adapting the architecture to data flows, and using asset and device identities [7]. In other words, it controls how data travels in the network with the cloud server with control is placed. The cloud infrastructure must be taken into consideration as well, rather if it is public, private, or hybrid. In correlation, with the design of the network. The fundamental model of cloud security can make use of a reactive model, that of perimeter security where the connections and flow of data originating internally are trusted more than that originating externally, and mission-critical components of the network section off by the firewall [7]. So, the issue at hand is the way cloud models are created and used in a conventional matter and can be attacked using the unique parameter by spoofing and or changing entirely. Hence, choosing the right cloud infrastructure is critical to having a proper solution for the network being developed.

7 CONCLUSION

Zero-trust is starting to become a popular solution scheme in the security world but, information on implementing the concepts of zero-trust is vague. This is not without reason the idea is like a blanket statement of key points that need to be covered to achieve a zero-trust model or solution. The details on how to unitize zero-trust are strictly based on the network and architecture to which it is being applied. Hence, the reason that reading on how to implement zero-trust may seem vague. This is the goal of this paper and documentation details to achieve zero-trust and to deliver a scalable solution that would need to be tweaked based on specific needs on the network and architecture. The solution given in this paper should allow for others who would like to implement the zero-trust model with the aid of these readings. OKTA as IAM, Cloudflare as access control and firewall, and Tailscale as a secure tunnel for devices on the network and outside. Should allow for even an enterprise network to use this zero-trust solution on its architecture.

REFERENCES

- [1] Juanita Koilpillai and Nya Alison Murray. Software-Defined Perimeter (SDP) and Zero Trust | CSA. <https://cloudsecurityalliance.org>. Retrieved June 1, 2022 from <https://cloudsecurityalliance.org/artifacts/software-defined-perimeter-and-zero-trust/>
- [2] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. 2020. Zero Trust Architecture. NIST SP (2020). DOI:<https://doi.org/10.6028/nist.sp.800-207>
- [3] Security Technical White Paper | Okta. Okta. Retrieved June 4, 2022 from <https://www.okta.com/resources/whitepaper/okta-security-technical-white-paper/>
- [4] Paul A Grassi, Michael E Garcia, and James L Fenton. 2017. Digital identity guidelines: revision 3. (2017). DOI:<https://doi.org/10.6028/nist.sp.800-63-3>
- [5] [Azure] 2022. Shared responsibility in the cloud - Microsoft Azure | Microsoft Docs. Microsoft Build. Retrieved February 26, 2022 from <https://docs.microsoft.com/enus/azure/security/fundamentals/shared-responsibility>
- [6] Scott Rose. 2021. Draft NIST Cybersecurity White Paper, Planning for a Zero Trust . Retrieved April 5, 2022 from <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.o8042021-draft.pdf>
- [7] Sarkar, S. et al. 2022. Security of Zero Trust Networks in Cloud Computing: A Comparative Review. Sustainability. 14, 18 (Sep. 2022), 11213. DOI:<https://doi.org/10.3390/su141811213>
- [8] Tailscale (2022) Tailscale. Tailscale . Available at: <https://tailscale.com/kb/1151/what-is-tailscale/> (Accessed: November 9, 2022).
- [9] Anon. Zero Trust Network Access (ZTNA): Zero trust. Retrieved November 9, 2022 from <https://www.cloudflare.com/products/zero-trust/zero-trust-network-access/>